

Incident Report — Entra ID Device Code Phishing: Token Theft

SOC Analysis & Triage Assignment · Zaio Cybersecurity Bootcamp · Intermediate Operation

1. Header / Metadata

Operation ID	OPS-2026-0514-02
Operation name	Entra ID Device Code Phishing: Token Theft
Started (UTC)	2026-05-14 09:24:03
Closed (UTC)	2026-05-14 09:48:33
Analyst	Ndumiso Mbanjwa
Cohort	May26 Cybersecurity
Difficulty	Intermediate
Severity	Critical
Final verdict	True Positive
Status	Contained - Escalated for token/consent revocation, rogue app disablement, and password reset

2. Executive Summary

A Microsoft 365 user at Arlowick Financial Services, kate.henderson@arlowick-fs.com, received a phishing email pretending to be from Microsoft Teams IT Support. The email convinced her to complete a Microsoft device-code login. The Microsoft website itself was genuine, but the login code had been created by the attacker. By entering the code and approving the login, the user accidentally gave an attacker-controlled application called Teams Device Verifier permission to access her Microsoft 365 mailbox. The attacker did not need to steal her password and did not install any malware on her computer — instead, Microsoft issued the attacker a valid digital access token, which let the attacker access the user's email as if they were an approved application. The attacker then searched through the victim's inbox looking for emails that might contain passwords or other credentials. This is a confirmed True Positive: every stage of this chain — from the phishing email, through the token theft, to the specific mailbox searches — is directly shown in the email, sign-in, and cloud activity logs, with no gaps in the evidence. The account's access has been revoked and a password reset is pending.

3. Operation Details

Triggering detection	A high-priority alert fired for a device-code sign-in coming from an address outside the company's normal network
Source	185.125.0.44 (the address that completed the sign-in and received the access token); 185.125.0.91 (used afterward to

	search the mailbox)
Destination	kate.henderson@arlowick-fs.com's Microsoft 365 mailbox
User / Host affected	kate.henderson@arlowick-fs.com (the Microsoft 365 account)
Artefact	The attacker-controlled application "Teams Device Verifier" (unique ID f2a9c817-3b4e-4d91-a7c0-8f1d2e3b5a6c)
Direction	Inbound: the phishing email and the attacker's login attempt. Outbound: the mailbox searches, carried out from the attacker's own infrastructure
Tool surfaces used	Security log platform (SIEM), Email, and Cloud activity logs

4. Investigation & Triage

Task	Objective	What I checked	Finding	Decision & reasoning	Fig. ref
Task 1 - Identify the compromised account	Work out whose account was taken over	The sign-in log for the suspicious login, expanded	kate.henderson@arlowick-fs.com — Microsoft's own risk score marked this sign-in high-risk, and no extra verification (MFA) was used	This is the only sign-in for this user that broke the normal pattern of a password plus extra verification, and no company security policy stepped in to block it	Fig. 2
Task 2 - Name the unusual login method	Identify the login method that should never normally show up for a regular user	The same sign-in log entry	"deviceCode" — a Microsoft login method meant for devices like smart TVs that can't easily show a normal login screen	This method is legitimate for devices without a keyboard or browser, but it is rarely appropriate for someone signing into everyday work apps from a normal computer — here, it was the trick itself	Fig. 3

Task 3 - Find the attacker's address	Identify the outside address that completed the login and made the first mailbox requests	The same sign-in log entry, cross-checked against the first mailbox-access records	185.125.0.44	This address is outside the company's known office and remote-work networks, and it matches both the sign-in and the first few mailbox-access requests	Fig. 2
Task 4 - Name the attacker's application	Identify the application that received the stolen access	The record of the permission being granted, and the application's ID within it	f2a9c817-3b4e-4d91-a7c0-8f1d2e3b5a6c, calling itself "Teams Device Verifier"	This is not a genuine Microsoft application, and it does not appear on the company's list of approved applications; it was granted permission to read email and to keep that access going forward	Fig. 3 / Fig. 4
Task 5 - Identify the phishing sender's domain	Work out where the phishing email actually came from	The email system's log, and its sender-verification results	ms-teams-notify[.]io — rated High Risk (25 out of 100) and failing all three standard email-authenticity checks	This is a lookalike domain built to resemble a Microsoft Teams address, and it failed every check that would normally confirm a sender is	Fig. 5 / Fig. 6

				who it claims to be	
Task 6 - Trace what the attacker accessed	Identify exactly what the attacker requested from the mailbox first	The cloud activity log for the mailbox request	A request for the first 50 messages in the inbox, including subject lines and sender details	This was the attacker's first, largest sweep of the inbox, followed by more specific searches for messages mentioning passwords or credentials	Fig. 7
Task 7 - Classify how the credentials were stolen	Identify the technique that covers stealing this kind of application access	Putting together everything found in Tasks 1 through 6 — no password was phished, no malware was used, and no software flaw was exploited	T1528 - Steal Application Access Token	This is confirmed directly by the platform's own classification of the permission-granting event, and matches the fact that the attacker only ever needed the user to approve a login, not to hand over a password	Fig. 8

5. Threat Intelligence

Indicator (defanged)	Tool	Result / score	Date checked (UTC)	Notes
Domain	ms-teams-notify[.]io	No record found	2026-08-30 (VirusTotal)	No VirusTotal history exists for this lookalike domain — treated as

				inconclusive, not as proof it's safe.
IPv4	185[.]125[.]0[.]44	0 out of 91 security companies flagged it	2026-08-30 (VirusTotal)	Registered to a small German hosting provider (AS200519), in the same address block as the second attacker address.
IPv4	185[.]125[.]0[.]91	0 out of 91 security companies flagged it	2026-08-30 (VirusTotal)	Same small German hosting provider and same address block as the sign-in address above.

Both outside addresses used in this attack sit in the same small block of addresses (185.125.0.0/22) rented from a single, low-profile German hosting provider, and neither one — nor the phishing domain — has any history on VirusTotal. That absence of outside confirmation is treated as inconclusive, not as proof anything here was safe: the case rests on the company's own records — the unusual login method, the permission handed to an unapproved application, and the specific mailbox searches that followed — not on outside reputation checks. Both addresses sharing the same small provider and address block is consistent with the attacker renting a single, low-cost hosting setup and using different addresses from it for the login and the later mailbox searches. The platform's own threat write-up separately attributes this technique to a group Microsoft calls Storm-2372, a cluster Microsoft has linked with medium confidence to Russian state interests, active in early 2025 using very similar Microsoft Teams/IT-support login tricks against government, non-profit, and professional-services targets. That attribution comes from the platform's own advisory material rather than being confirmed independently in this investigation beyond the three VirusTotal checks above.

6. Timeline (UTC)

Time (UTC)	Event
2026-05-14 09:24:03	The unusual login happens: kate.henderson@arlowick-fs.com signs in using the device-code method from 185.125.0.44, with no extra verification and no security policy stepping in (Critical)
2026-05-14 09:24:05	The attacker's application, Teams Device

	Verifier, is granted permission to read the mailbox and keep that access going forward (High)
2026-05-14 09:24:45	Microsoft's own systems flag the sign-in as high risk (High)
2026-05-14 09:31:14	The attacker requests the first 50 messages in the inbox from 185.125.0.44 (High)
2026-05-14 09:33:00-09:40:00	The attacker opens three specific messages from 185.125.0.44 (High)
2026-05-14 09:44:22	A second attacker address, 185.125.0.91, starts searching the mailbox for the first time (High)
2026-05-14 09:46:08	A second request for inbox messages comes from 185.125.0.91 (High)
2026-05-14 09:48:33	A final attempt from 185.125.0.91 fails because access is no longer accepted (Medium)
2026-05-14 11:17:00 (time shown in the email)	The phishing email "Action Required: Verify Your Teams Account Access" arrives from it-support@ms-teams-notify.io, failing every sender-verification check, containing the login code FKTP-7X9M

7. Indicators of Compromise

Type	Indicator (defanged)	Context
IPv4	185[.]125[.]0[.]44	Used to complete the sign-in and receive the access token (0 of 91 on VirusTotal)
IPv4	185[.]125[.]0[.]91	Used afterward to keep searching the mailbox (0 of 91 on VirusTotal)
Domain	ms-teams-notify[.]io	The domain the phishing email came from; it failed every sender-verification check (no VirusTotal record)
Email address	it-support@ms-teams-notify[.]io	The exact address the phishing email was sent from
Application ID	f2a9c817-3b4e-4d91-a7c0-8f1d2e3b5a6c	The attacker's application, calling itself "Teams Device Verifier"
Mailbox request path	/v1.0/users/kate.henderson@arlowick-fs.com/mailFolders/inbox/messages	The exact request used for the first, largest sweep of the inbox

Login code	FKTP-7X9M	The short-lived login code included in the phishing email
------------	-----------	---

STIX 2.1 Bundle

```
{
  "type": "bundle",
  "id": "bundle--343a51e3-e29d-4ed3-9307-423793a4e745",
  "objects": [
    {
      "type": "identity",
      "spec_version": "2.1",
      "id": "identity--4bed9f2c-8495-4fb1-9fd7-49f005488415",
      "created": "2026-08-30T17:48:58.108442Z",
      "modified": "2026-08-30T17:48:58.108442Z",
      "name": "Ndumiso Mbanjwa (May26 Cybersecurity SOC Triage)",
      "description": "Analyst-produced threat intelligence from an independent SOC investigation on socsimulator.com (Investigation mode): Entra ID Device Code Phishing: Token Theft.",
      "identity_class": "individual"
    },
    {
      "type": "identity",
      "spec_version": "2.1",
      "id": "identity--fd5d9730-0639-4817-80b9-b3f0bcd78515",
      "created": "2026-08-30T17:48:58.108651Z",
      "modified": "2026-08-30T17:48:58.108651Z",
      "name": "Arlowick Financial Services",
      "description": "Victim organization; a financial services firm using Microsoft 365 and Entra ID for identity and collaboration. The targeted mailbox belonged to kate.henderson@arlowick-fs.com.",
      "identity_class": "organization"
    },
    {
      "type": "threat-actor",
      "spec_version": "2.1",
      "id": "threat-actor--862899d2-c987-4779-af99-965532160d53",
      "created": "2026-08-30T17:48:58.108748Z",
      "modified": "2026-08-30T17:48:58.108748Z",
      "name": "Storm-2372",
      "description": "Microsoft threat actor designation for a cluster assessed with medium confidence to align with Russian state interests. Campaign observed in early 2025 targeted government, non-governmental organizations, and professional services entities across Europe, North America, and the Middle East, using device-code phishing lures impersonating Microsoft Teams meeting invitations and IT support notifications. Assessed to be motivated by intelligence collection rather than financial gain. Attribution here follows the in-platform vendor advisory and is not independently confirmed against external threat intel beyond the platform's own content.",
      "threat_actor_types": [
        "nation-state"
      ]
    }
  ]
}
```

```

    ],
    "sophistication": "advanced",
    "resource_level": "government",
    "primary_motivation": "organizational-gain"
  },
  {
    "type": "tool",
    "spec_version": "2.1",
    "id": "tool--20d98506-8b58-400b-bd73-a7b853520b97",
    "created": "2026-08-30T17:48:58.109065Z",
    "modified": "2026-08-30T17:48:58.109065Z",
    "name": "Teams Device Verifier (rogue OAuth application)",
    "description": "Attacker-registered OAuth application (clientId f2a9c817-3b4e-4d91-a7c0-8f1d2e3b5a6c) that is not a Microsoft first-party application and does not appear in the corporate enterprise app registry. Used to initiate an OAuth device-code flow, was granted Mail.Read and offline_access scope via a delegated permission grant with consentType AllPrincipals, and was then used from the attacker's own infrastructure to enumerate and read the victim's mailbox via Microsoft Graph.",
    "tool_types": [
      "remote-access"
    ]
  },
  {
    "type": "attack-pattern",
    "spec_version": "2.1",
    "id": "attack-pattern--9cd8c757-5572-454d-8286-94f2ba6d180e",
    "created": "2026-08-30T17:48:58.109164Z",
    "modified": "2026-08-30T17:48:58.109164Z",
    "name": "Phishing: Spearphishing Link",
    "description": "Phishing email from it-support@ms-teams-notify.io ('Action Required: Verify Your Teams Account Access', 2026-05-14 11:17 AM) directed the victim to the genuine microsoft.com/devicelogin URL and instructed her to enter attacker-supplied device code FKTP-7X9M. The sending domain failed SPF, DKIM, and DMARC and scored High Risk (25/100) on sender reputation.",
    "external_references": [
      {
        "source_name": "mitre-attack",
        "url": "https://attack.mitre.org/techniques/T1566/002/",
        "external_id": "T1566.002"
      }
    ]
  },
  {
    "type": "attack-pattern",
    "spec_version": "2.1",
    "id": "attack-pattern--6f88c2a2-d083-4ab2-819a-e5f76bb7df58",
    "created": "2026-08-30T17:48:58.109324Z",
    "modified": "2026-08-30T17:48:58.109324Z",
    "name": "Steal Application Access Token",
    "description": "Completing the OAuth device-code flow at the real Microsoft endpoint handed the attacker-controlled application (Teams Device Verifier, clientId f2a9c817-3b4e-4d91-a7c0-8f1d2e3b5a6c) a valid access token and refresh token for the victim's account with Mail.Read and offline_access scope \u2014 no password was

```

phished, no malware was deployed, and no vulnerability was exploited. Confirmed platform finding (Task 7).",

```
    "external_references": [
      {
        "source_name": "mitre-attack",
        "url": "https://attack.mitre.org/techniques/T1528/",
        "external_id": "T1528"
      }
    ]
  },
  {
    "type": "attack-pattern",
    "spec_version": "2.1",
    "id": "attack-pattern--0987cf9f-d55c-46bd-9259-f8e36bcbe722",
    "created": "2026-08-30T17:48:58.109443Z",
    "modified": "2026-08-30T17:48:58.109443Z",
    "name": "Valid Accounts: Cloud Accounts",
    "description": "All subsequent Microsoft Graph API activity against the
victim's mailbox used the legitimately issued OAuth token and therefore appears in
cloud audit logs as authenticated API activity performed by the victim's own
identity.",
    "external_references": [
      {
        "source_name": "mitre-attack",
        "url": "https://attack.mitre.org/techniques/T1078/004/",
        "external_id": "T1078.004"
      }
    ]
  },
  {
    "type": "attack-pattern",
    "spec_version": "2.1",
    "id": "attack-pattern--81c25f46-4145-4c33-b8ca-3fa71c9a6f6e",
    "created": "2026-08-30T17:48:58.109595Z",
    "modified": "2026-08-30T17:48:58.109595Z",
    "name": "Email Collection: Remote Email Collection",
    "description": "The rogue application called the Microsoft Graph inbox
endpoint (/v1.0/users/kate.henderson@arlowick-fs.com/mailFolders/inbox/messages) and
paged through 50 messages (top=50,
select=id,subject,from,receivedDateTime,hasAttachments), then issued targeted
GetMessage and SearchMessages calls filtering for subjects containing credentials and
passwords. Confirmed platform finding (Task 6).",
    "external_references": [
      {
        "source_name": "mitre-attack",
        "url": "https://attack.mitre.org/techniques/T1114/002/",
        "external_id": "T1114.002"
      }
    ]
  },
  {
    "type": "indicator",
    "spec_version": "2.1",
```

```

        "id": "indicator--e2d8028f-ac76-499a-9dec-5217692751d6",
        "created": "2026-08-30T17:48:58.109712Z",
        "modified": "2026-08-30T17:48:58.109712Z",
        "name": "Phishing sender domain",
        "description": "Microsoft-lookalike domain used to send the device-code
phishing lure. Failed SPF, DKIM, and DMARC; sender reputation score 25/100 (High Risk).
Confirmed platform finding (Task 5).",
        "indicator_types": [
            "malicious-activity"
        ],
        "pattern": "[domain-name:value = 'ms-teams-notify.io']",
        "pattern_type": "stix",
        "pattern_version": "2.1",
        "valid_from": "2026-05-14T11:17:00Z"
    },
    {
        "type": "indicator",
        "spec_version": "2.1",
        "id": "indicator--e731eb2c-880d-46b4-9717-2e197b5efbe8",
        "created": "2026-08-30T17:48:58.114688Z",
        "modified": "2026-08-30T17:48:58.114688Z",
        "name": "Phishing sender address",
        "description": "Sending mailbox for the 'Action Required: Verify Your Teams
Account Access' phishing email.",
        "indicator_types": [
            "malicious-activity"
        ],
        "pattern": "[email-addr:value = 'it-support@ms-teams-notify.io']",
        "pattern_type": "stix",
        "pattern_version": "2.1",
        "valid_from": "2026-05-14T11:17:00Z"
    },
    {
        "type": "indicator",
        "spec_version": "2.1",
        "id": "indicator--31c554a2-ac12-4f93-9f89-4da79c3e4d98",
        "created": "2026-08-30T17:48:58.115639Z",
        "modified": "2026-08-30T17:48:58.115639Z",
        "name": "Device-code sign-in source IP",
        "description": "External IP address that completed the OAuth device-code
flow for the compromised account, outside the corporate egress ranges, with MFA not
used and conditional-access status notApplied. Confirmed platform finding (Task 3).",
        "indicator_types": [
            "malicious-activity"
        ],
        "pattern": "[ipv4-addr:value = '185.125.0.44']",
        "pattern_type": "stix",
        "pattern_version": "2.1",
        "valid_from": "2026-05-14T09:24:03Z"
    },
    {
        "type": "indicator",
        "spec_version": "2.1",

```

```

      "id": "indicator--06cbfe3f-b0c0-41ff-9c55-1297475b57fc",
      "created": "2026-08-30T17:48:58.11663Z",
      "modified": "2026-08-30T17:48:58.11663Z",
      "name": "Secondary Graph API source IP",
      "description": "Second external IP address observed issuing
ListMessages/SearchMessages Graph API calls against the victim's mailbox later in the
session, distinct from the initial sign-in IP \u2014 consistent with attacker
infrastructure rotation between authentication and collection stages.",
      "indicator_types": [
        "anomalous-activity"
      ],
      "pattern": "[ipv4-addr:value = '185.125.0.91']",
      "pattern_type": "stix",
      "pattern_version": "2.1",
      "valid_from": "2026-05-14T09:44:22Z"
    },
    {
      "type": "indicator",
      "spec_version": "2.1",
      "id": "indicator--2a6a36df-68d3-4374-b23f-c130e8539ca1",
      "created": "2026-08-30T17:48:58.117148Z",
      "modified": "2026-08-30T17:48:58.117148Z",
      "name": "Rogue OAuth application client ID",
      "description": "Client ID of the attacker-registered application ('Teams
Device Verifier') that received the stolen access/refresh token. Not a Microsoft first-
party application; not present in the corporate enterprise app registry. Confirmed
platform finding (Task 4).",
      "indicator_types": [
        "malicious-activity"
      ],
      "pattern": "[user-account:x_client_id = 'f2a9c817-3b4e-4d91-a7c0-
8f1d2e3b5a6c']",
      "pattern_type": "stix",
      "pattern_version": "2.1",
      "valid_from": "2026-05-14T09:24:05Z"
    },
    {
      "type": "indicator",
      "spec_version": "2.1",
      "id": "indicator--a8c32603-d8da-4488-94ef-f56675eea4fd",
      "created": "2026-08-30T17:48:58.118114Z",
      "modified": "2026-08-30T17:48:58.118114Z",
      "name": "Compromised Entra user principal",
      "description": "Entra UPN whose OAuth token was stolen via the device-code
phishing flow. Confirmed platform finding (Task 1).",
      "indicator_types": [
        "compromised"
      ],
      "pattern": "[user-account:account_login = 'kate.henderson@arlowick-
fs.com']",
      "pattern_type": "stix",
      "pattern_version": "2.1",
      "valid_from": "2026-05-14T09:24:03Z"
    }
  ]
}

```

```

    },
    {
      "type": "indicator",
      "spec_version": "2.1",
      "id": "indicator--86c72eeb-5641-49ce-b809-77281fbf3469",
      "created": "2026-08-30T17:48:58.118928Z",
      "modified": "2026-08-30T17:48:58.118928Z",
      "name": "Graph API mailbox enumeration endpoint",
      "description": "Full Graph API request path used for the attacker's first,
and largest, mailbox enumeration call (top=50 messages, paged, filtered for credential-
related subjects). Confirmed platform finding (Task 6).",
      "indicator_types": [
        "malicious-activity"
      ],
      "pattern": "[url:value =
'https://graph.microsoft.com/v1.0/users/kate.henderson@arlowick-
fs.com/mailFolders/inbox/messages']",
      "pattern_type": "stix",
      "pattern_version": "2.1",
      "valid_from": "2026-05-14T09:31:14Z"
    },
    {
      "type": "indicator",
      "spec_version": "2.1",
      "id": "indicator--2c5b343c-7b8f-454a-9c75-226f422d7560",
      "created": "2026-08-30T17:48:58.119753Z",
      "modified": "2026-08-30T17:48:58.119753Z",
      "name": "Phishing lure device code",
      "description": "Short-lived (~15 minute) OAuth device-code value embedded
in the phishing email body, provided to the victim to complete the attacker-initiated
device-code flow at the genuine microsoft.com/devicelogs page.",
      "indicator_types": [
        "malicious-activity"
      ],
      "pattern": "[x-oauth-device-code:value = 'FKTP-7X9M']",
      "pattern_type": "stix",
      "pattern_version": "2.1",
      "valid_from": "2026-05-14T11:17:00Z"
    },
    {
      "type": "relationship",
      "spec_version": "2.1",
      "id": "relationship--596b358c-705d-4dda-a9a4-8696fbf6d6ad",
      "created": "2026-08-30T17:48:58.120449Z",
      "modified": "2026-08-30T17:48:58.120449Z",
      "relationship_type": "uses",
      "description": "Storm-2372 lures impersonate Microsoft Teams meeting
invitations and IT support notifications to deliver device-code phishing.",
      "source_ref": "threat-actor--862899d2-c987-4779-af99-965532160d53",
      "target_ref": "attack-pattern--9cd8c757-5572-454d-8286-94f2ba6d180e"
    },
    {
      "type": "relationship",

```

```

        "spec_version": "2.1",
        "id": "relationship--d20ecd88-285d-45b0-b02c-ad5b58fecf4e",
        "created": "2026-08-30T17:48:58.120836Z",
        "modified": "2026-08-30T17:48:58.120836Z",
        "relationship_type": "uses",
        "description": "Attacker-controlled OAuth application used to initiate the
device-code request and receive the stolen token.",
        "source_ref": "threat-actor--862899d2-c987-4779-af99-965532160d53",
        "target_ref": "tool--20d98506-8b58-400b-bd73-a7b853520b97"
    },
    {
        "type": "relationship",
        "spec_version": "2.1",
        "id": "relationship--6f70a90d-929f-44b9-b20b-40559da45970",
        "created": "2026-08-30T17:48:58.120944Z",
        "modified": "2026-08-30T17:48:58.120944Z",
        "relationship_type": "indicates",
        "description": "Sending domain for the spearphishing link lure.",
        "source_ref": "indicator--e2d8028f-ac76-499a-9dec-5217692751d6",
        "target_ref": "attack-pattern--9cd8c757-5572-454d-8286-94f2ba6d180e"
    },
    {
        "type": "relationship",
        "spec_version": "2.1",
        "id": "relationship--74e0bc19-b4fc-44f8-81aa-76f69292b207",
        "created": "2026-08-30T17:48:58.121058Z",
        "modified": "2026-08-30T17:48:58.121058Z",
        "relationship_type": "indicates",
        "description": "Sending address for the spearphishing link lure.",
        "source_ref": "indicator--e731eb2c-880d-46b4-9717-2e197b5efbe8",
        "target_ref": "attack-pattern--9cd8c757-5572-454d-8286-94f2ba6d180e"
    },
    {
        "type": "relationship",
        "spec_version": "2.1",
        "id": "relationship--7d8b49cc-7ed3-481a-8815-4a29ada53f5f",
        "created": "2026-08-30T17:48:58.121253Z",
        "modified": "2026-08-30T17:48:58.121253Z",
        "relationship_type": "indicates",
        "description": "Device code embedded in the phishing lure body.",
        "source_ref": "indicator--2c5b343c-7b8f-454a-9c75-226f422d7560",
        "target_ref": "attack-pattern--9cd8c757-5572-454d-8286-94f2ba6d180e"
    },
    {
        "type": "relationship",
        "spec_version": "2.1",
        "id": "relationship--eb810075-b440-435e-b415-935a17e38f45",
        "created": "2026-08-30T17:48:58.121349Z",
        "modified": "2026-08-30T17:48:58.121349Z",
        "relationship_type": "related-to",
        "description": "Target of the phishing email.",
        "source_ref": "indicator--a8c32603-d8da-4488-94ef-f56675eea4fd",
        "target_ref": "attack-pattern--9cd8c757-5572-454d-8286-94f2ba6d180e"
    }

```

```

    },
    {
      "type": "relationship",
      "spec_version": "2.1",
      "id": "relationship--41b27156-167b-4f5c-962e-44721d442dc2",
      "created": "2026-08-30T17:48:58.121442Z",
      "modified": "2026-08-30T17:48:58.121442Z",
      "relationship_type": "indicates",
      "description": "Source IP that completed the device-code authorization and
received the stolen token.",
      "source_ref": "indicator--31c554a2-ac12-4f93-9f89-4da79c3e4d98",
      "target_ref": "attack-pattern--6f88c2a2-d083-4ab2-819a-e5f76bb7df58"
    },
    {
      "type": "relationship",
      "spec_version": "2.1",
      "id": "relationship--bad4b854-aa00-4455-aa23-4ca41c577f75",
      "created": "2026-08-30T17:48:58.121565Z",
      "modified": "2026-08-30T17:48:58.121565Z",
      "relationship_type": "uses",
      "description": "Application that received the OAuth access and refresh
tokens.",
      "source_ref": "tool--20d98506-8b58-400b-bd73-a7b853520b97",
      "target_ref": "attack-pattern--6f88c2a2-d083-4ab2-819a-e5f76bb7df58"
    },
    {
      "type": "relationship",
      "spec_version": "2.1",
      "id": "relationship--3b62f197-d2ba-4084-86f5-c4f710a47383",
      "created": "2026-08-30T17:48:58.121661Z",
      "modified": "2026-08-30T17:48:58.121661Z",
      "relationship_type": "indicates",
      "description": "Client ID identifying the token recipient application.",
      "source_ref": "indicator--2a6a36df-68d3-4374-b23f-c130e8539ca1",
      "target_ref": "attack-pattern--6f88c2a2-d083-4ab2-819a-e5f76bb7df58"
    },
    {
      "type": "relationship",
      "spec_version": "2.1",
      "id": "relationship--b15e35f6-3a11-4eb7-a919-67fa87275b11",
      "created": "2026-08-30T17:48:58.121755Z",
      "modified": "2026-08-30T17:48:58.121755Z",
      "relationship_type": "uses",
      "description": "Subsequent Graph API activity used the legitimately issued
token, appearing as authenticated activity by the victim's identity.",
      "source_ref": "tool--20d98506-8b58-400b-bd73-a7b853520b97",
      "target_ref": "attack-pattern--0987cf9f-d55c-46bd-9259-f8e36bcbe722"
    },
    {
      "type": "relationship",
      "spec_version": "2.1",
      "id": "relationship--d35e71cc-bc5d-43e0-a03c-d89e8945574e",
      "created": "2026-08-30T17:48:58.121847Z",

```

```

        "modified": "2026-08-30T17:48:58.121847Z",
        "relationship_type": "related-to",
        "description": "Identity whose valid cloud account token was reused for
post-compromise access.",
        "source_ref": "indicator--a8c32603-d8da-4488-94ef-f56675eea4fd",
        "target_ref": "attack-pattern--0987cf9f-d55c-46bd-9259-f8e36bcbe722"
    },
    {
        "type": "relationship",
        "spec_version": "2.1",
        "id": "relationship--1d5134e5-5f71-4d49-a842-0171d243692f",
        "created": "2026-08-30T17:48:58.121937Z",
        "modified": "2026-08-30T17:48:58.121937Z",
        "relationship_type": "uses",
        "description": "Used the stolen token to call Graph mail endpoints and
collect messages from the victim's inbox.",
        "source_ref": "tool--20d98506-8b58-400b-bd73-a7b853520b97",
        "target_ref": "attack-pattern--81c25f46-4145-4c33-b8ca-3fa71c9a6f6e"
    },
    {
        "type": "relationship",
        "spec_version": "2.1",
        "id": "relationship--af96f545-2216-428a-8eac-6aefb70009cd",
        "created": "2026-08-30T17:48:58.122037Z",
        "modified": "2026-08-30T17:48:58.122037Z",
        "relationship_type": "indicates",
        "description": "Graph API path targeted for the first and largest mailbox
enumeration call.",
        "source_ref": "indicator--86c72eeb-5641-49ce-b809-77281fbf3469",
        "target_ref": "attack-pattern--81c25f46-4145-4c33-b8ca-3fa71c9a6f6e"
    },
    {
        "type": "relationship",
        "spec_version": "2.1",
        "id": "relationship--4e27b358-f954-4b8c-947b-53d365639fe5",
        "created": "2026-08-30T17:48:58.122132Z",
        "modified": "2026-08-30T17:48:58.122132Z",
        "relationship_type": "indicates",
        "description": "Source IP observed issuing subsequent mailbox-read Graph
API calls.",
        "source_ref": "indicator--06cbfe3f-b0c0-41ff-9c55-1297475b57fc",
        "target_ref": "attack-pattern--81c25f46-4145-4c33-b8ca-3fa71c9a6f6e"
    },
    {
        "type": "relationship",
        "spec_version": "2.1",
        "id": "relationship--78183906-e1e3-415b-a2b7-a2a4672f3e28",
        "created": "2026-08-30T17:48:58.122227Z",
        "modified": "2026-08-30T17:48:58.122227Z",
        "relationship_type": "related-to",
        "description": "Distinct IP addresses used across the authentication and
collection stages, consistent with infrastructure rotation.",
        "source_ref": "indicator--06cbfe3f-b0c0-41ff-9c55-1297475b57fc",

```

```

      "target_ref": "indicator--31c554a2-ac12-4f93-9f89-4da79c3e4d98"
    },
    {
      "type": "relationship",
      "spec_version": "2.1",
      "id": "relationship--6d4f7095-a7e0-4c51-9d26-4cbb6f6c3f44",
      "created": "2026-08-30T17:48:58.122314Z",
      "modified": "2026-08-30T17:48:58.122314Z",
      "relationship_type": "related-to",
      "description": "Application granted a delegated token scoped to this
account's mailbox.",
      "source_ref": "indicator--2a6a36df-68d3-4374-b23f-c130e8539ca1",
      "target_ref": "indicator--a8c32603-d8da-4488-94ef-f56675eea4fd"
    }
  ]
}

```

8. MITRE ATT&CK Mapping

Tactic	Technique	ID
Initial Access	Phishing: Spearphishing Link	T1566.002
Credential Access	Steal Application Access Token	T1528
Defense Evasion / Persistence	Valid Accounts: Cloud Accounts	T1078.004
Collection	Email Collection: Remote Email Collection	T1114.002

9. Impact & Containment

Impact: the attacker was handed valid access to read kate.henderson@arlowick-fs.com's mailbox, and used that access — from their own outside infrastructure — to search the inbox for messages likely to contain passwords or other credentials. Because the attacker also received a token that renews itself, this exposure isn't limited to just the one login session that was observed. Containment steps, in priority order: (1) cancel all permissions and access granted to the "Teams Device Verifier" application across the whole organization, since this kind of renewing token can stay valid for weeks or months after the original phishing email is reported; (2) force a password reset and have the user set up extra verification (MFA) again; (3) check whether any other employees approved the same application; (4) turn off or restrict this device-code login method for normal employee accounts, since it's really meant for devices without a keyboard or screen; (5) block the phishing domain at the email gateway and search company mailboxes for the same message; (6) review whether employees should be allowed to approve third-party applications requesting access to company email without IT approval first.

10. Conclusion & Recommendations

Final verdict: True Positive. This was a confirmed phishing attack. The attacker did not steal a password in the usual sense — instead, they tricked the victim into approving access through a genuine Microsoft login page. That gave an attacker-controlled application permission to read the victim's mailbox, which the attacker then searched for passwords and other sensitive information. Every stage of this chain — the phishing email, the login trick, the permission grant, and the specific mailbox searches — is directly shown in the company's own records, with no gaps in the evidence.

Recommendations:

1. Restrict this kind of device-code login so it's only available where it's genuinely needed, not for everyday employee sign-ins from normal computers.
2. Don't let employees approve unverified third-party applications requesting access to company email without IT/admin sign-off first.
3. Set up monitoring for unusual applications suddenly being granted mailbox access, especially right after a login from an unfamiliar location or provider.
4. Treat this kind of renewing access token as a standing risk: cancelling the application's permission and the token itself must be part of the standard response, not just resetting the user's password.
5. Train employees to understand that phishing attacks can use a completely genuine Microsoft website and may never actually ask for a password — this attack worked precisely because it didn't fit the pattern people are usually warned about.

11. Evidence / Screenshots

Figure	Caption	Referenced in
Figure 1	The operation header: title, difficulty (Intermediate), time/points, tools used, and scenario description	Section 3
Figure 2	The sign-in log entry, expanded: kate.henderson@arlowick-fs.com, address 185.125.0.44, marked high risk, no extra verification used	Task 1 / Task 3
Figure 3	The same sign-in entry: application name "Teams Device Verifier", login method deviceCode, application ID f2a9c817-...	Task 2 / Task 4
Figure 4	The permission-granting	Task 4

	event, expanded: application Teams Device Verifier granted mailbox-read access and renewing access	
Figure 5	The email system's sender-verification panel for it-support@ms-teams-notify.io — High Risk 25/100, failing every check	Task 5
Figure 6	The full phishing email body: "Action Required: Verify Your Teams Account Access", containing login code FKTP-7X9M	Task 5
Figure 7	The mailbox-request event, expanded: a request for the first 50 inbox messages	Task 6
Figure 8	The Task 7 confirmed finding (T1528) alongside the operation's list of flagged behaviors	Task 7
Figure 9	The operation-completion screen: all 7 tasks answered correctly	Section 3
Figure 10	The platform's own threat write-up: summary and the section describing the Storm-2372 group and campaign	Section 5
Figure 11	The platform's own threat write-up: how the attack unfolds, matching technique list, and suggested detections	Section 5
Figure 12	VirusTotal lookup for ms-teams-notify.io — no record found	Section 5
Figure 13	VirusTotal details for 185.125.0.44 (0 of 91 flagged, small German hosting provider)	Section 5
Figure 14	VirusTotal details for 185.125.0.91 (0 of 91 flagged, same hosting provider and address block)	Section 5

Figure 1. The operation header: title, difficulty (Intermediate), time/points, tools used, and scenario description.

One payment. Lifetime Pro access.
Become an Early Adopter. Keep every Pro feature. No renewals.

\$194.35

once
Offer ends August 31 · \$299

Get Lifetime >

SOC Simulator

Operations ▾Shift Mode ▾Career ▾Community ▾

Q Search...

Daily 0/1

Upgrade

Training Operations > Entra ID Device Code Phishing: Token Theft

Q Entra ID Device Code Phishing: Token Theft

SaveLike



A Microsoft 365 user at a financial services firm receives a convincing phishing email asking her to enter a device code at the legitimate Microsoft device login page. The code completes the attacker's OAuth request, handing over a valid token. Working through Entra sign-in logs, Graph audit events, and the email trail, trace how the token was stolen and what the attacker read from the victim's mailbox.

Intermediate

45m

50 pts

SIEM / EMAIL / CLOUD

First Blood: Michael

Report Issue

Start Operation

Tasks

0/7

1 Identify the compromised account

2 Name the authentication anomaly

SIEM

Cloud

Email

Threat Intel

Start the operation to load the data and investigate.

Feedback

Figure 2. The sign-in log entry, expanded: kate.henderson@arlowick-fs.com, address 185.125.0.44, marked high risk, no extra verification used.

SOC Simulator

Operations ▾Shift Mode ▾Career ▾Community ▾

Q Search...

Daily 0/1

Upgrade

Tasks

0/7

1 Identify the compromised account

Who did the attacker target?

Arlowick Financial Services uses Microsoft 365 and Entra ID for identity and collaboration. Overnight, authentication activity surfaced that does not match any user's normal pattern. Separate the anomalous sign-in events from the routine corporate activity and identify the Entra user principal name (UPN) of the account whose token was compromised.

Normal corporate sign-ins come through password+MFA or oauth2 flows with MFA satisfied. Look for the principal in sign-in events that break that pattern.

Show Hint

Finding

Submit

conditionalAccessStatus

notApplied

ipAddress

185.125.0.44

mfaDetail

none

riskEventType

unfamiliarFeatures

riskLevelDuringSignIn

high

riskState

atRisk

status

[Object Object]

userPrincipalName

kate.henderson@arlowick-fs.com

Feedback

Figure 3. The same sign-in entry: application name "Teams Device Verifier", login method deviceCode, application ID f2a9c817-3b4e-4d91-a7c0-8f1d2e3b5a6c.

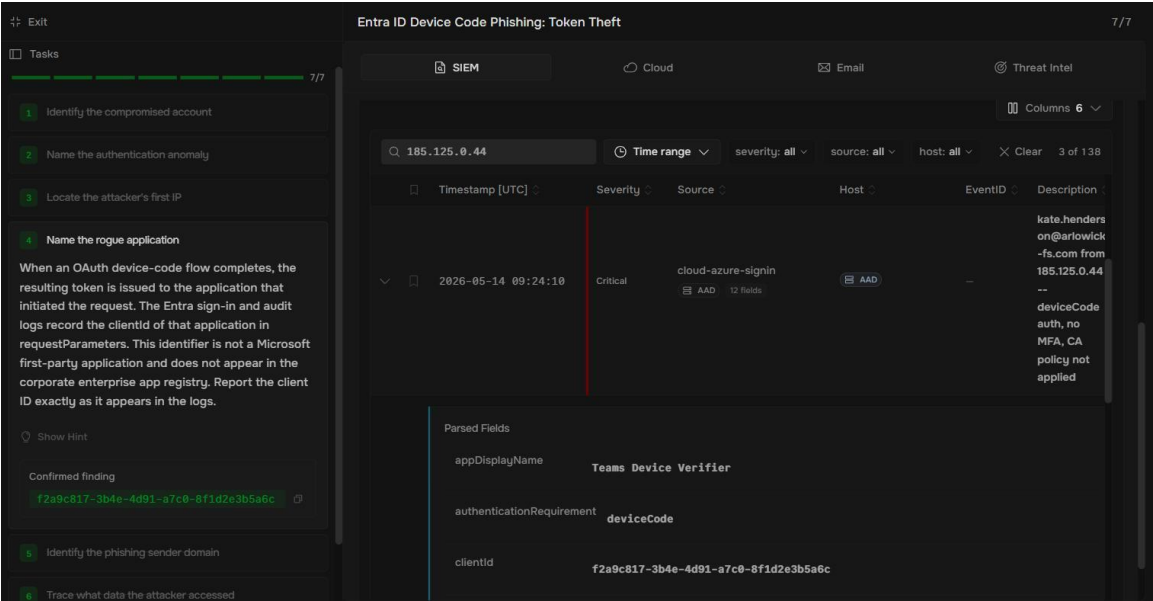


Figure 4. The permission-granting event, expanded: application Teams Device Verifier granted mailbox-read access and renewing access.

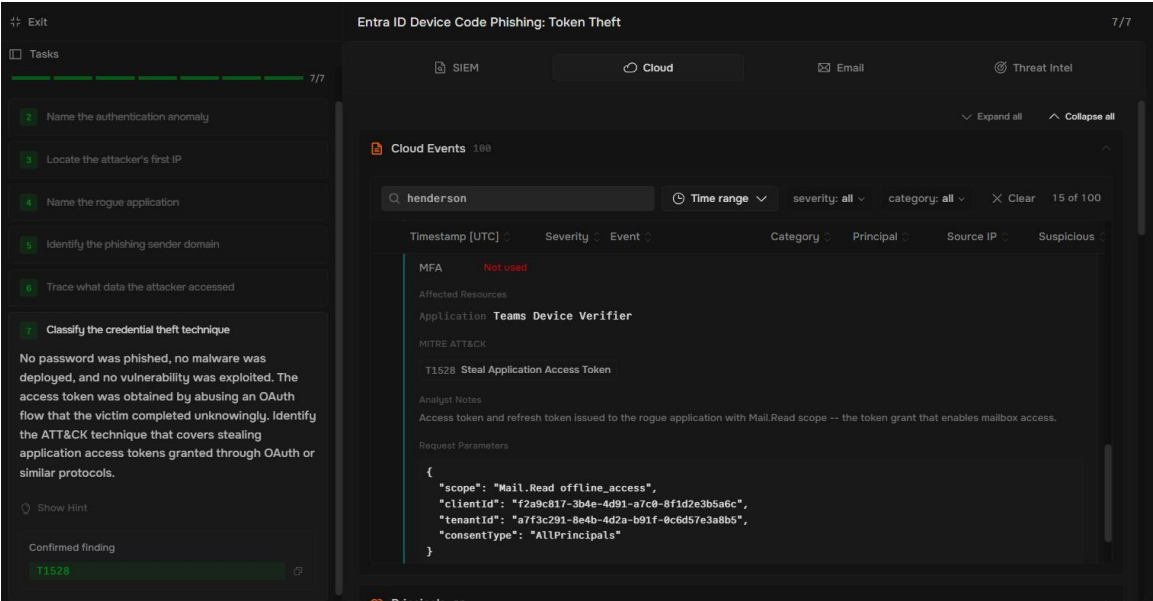


Figure 5. The email system's sender-verification panel for it-support@ms-teams-notify.io — High Risk 25/100, failing every check.

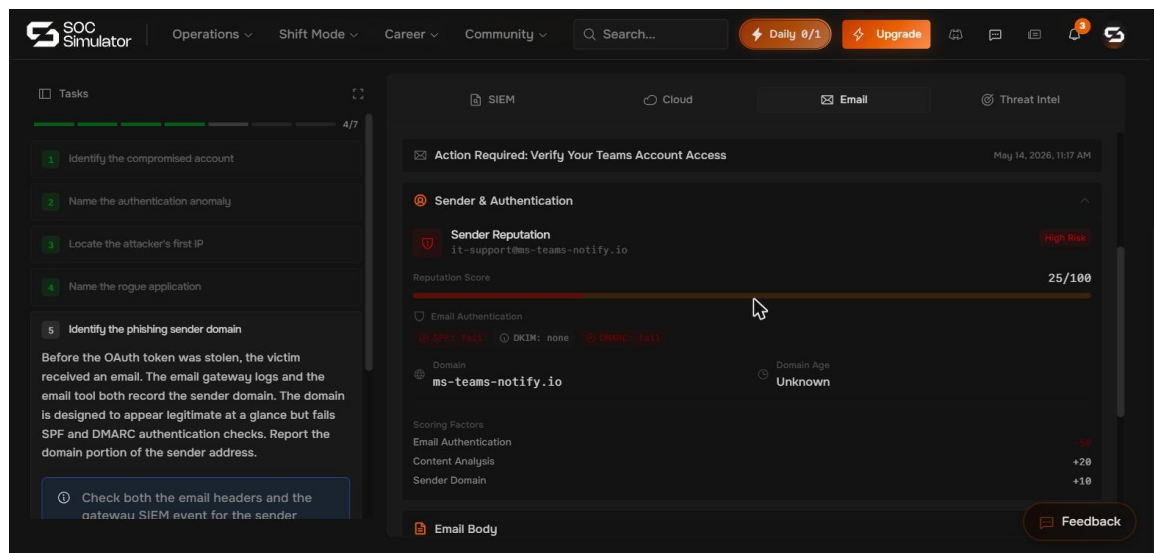


Figure 6. The full phishing email body: "Action Required: Verify Your Teams Account Access", containing login code FKTP-7X9M.

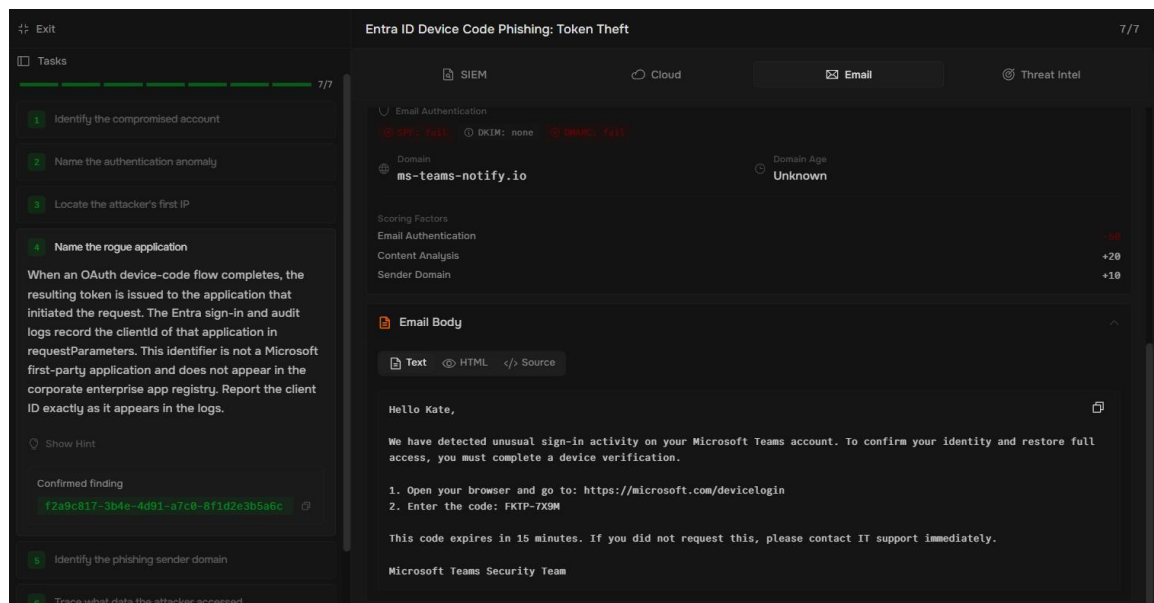


Figure 7. The mailbox-request event, expanded: a request for the first 50 inbox messages.

The screenshot displays the SOC Simulator interface. On the left, a 'Tasks' panel lists seven tasks, with the first task 'Name the authentication anomaly' highlighted. The main area shows a 'Cloud Events' section with a search filter 'henderson' and a 'Time range' dropdown. A table of events is visible, with one event expanded showing details for 'MailFolder: inbox'. The expanded event includes a 'MITRE ATT&CK' entry 'T1114.002 Email Collection' and 'Analyst Notes' describing a mailbox enumeration script. The 'Request Parameters' section shows a JSON object with fields like 'top', 'select', 'clientId', and 'requestPath'.

Figure 8. The Task 7 confirmed finding (T1528) alongside the operation's list of flagged behaviors.

The screenshot shows the SOC Simulator interface with a 'Tasks' panel on the left. The main area displays a 'Detection Rules Triggered' section with three rules: 'Device-code OAuth sign-in from external IP', 'Phishing email SPF and DMARC failure from lookalike domain', and 'Graph API mass mail read by unrecognized application'. Below this, a 'Severity Distribution' bar chart shows 1 Critical, 3 High, 3 Medium, and 130 Info events. A 'Sources' section lists various sources like 'cloud-azure-signin', 'web-nginx', and 'email-c365'. A 'Top Events' section shows 4624 events. The 'Security Logs' section lists tags like 'ca-policy', 'device-code', 'dmarc-fail', and 'graph-api'. The 'Confirmed finding' section on the left shows 'T1528'.

Figure 9. The operation-completion screen: all 7 tasks answered correctly.

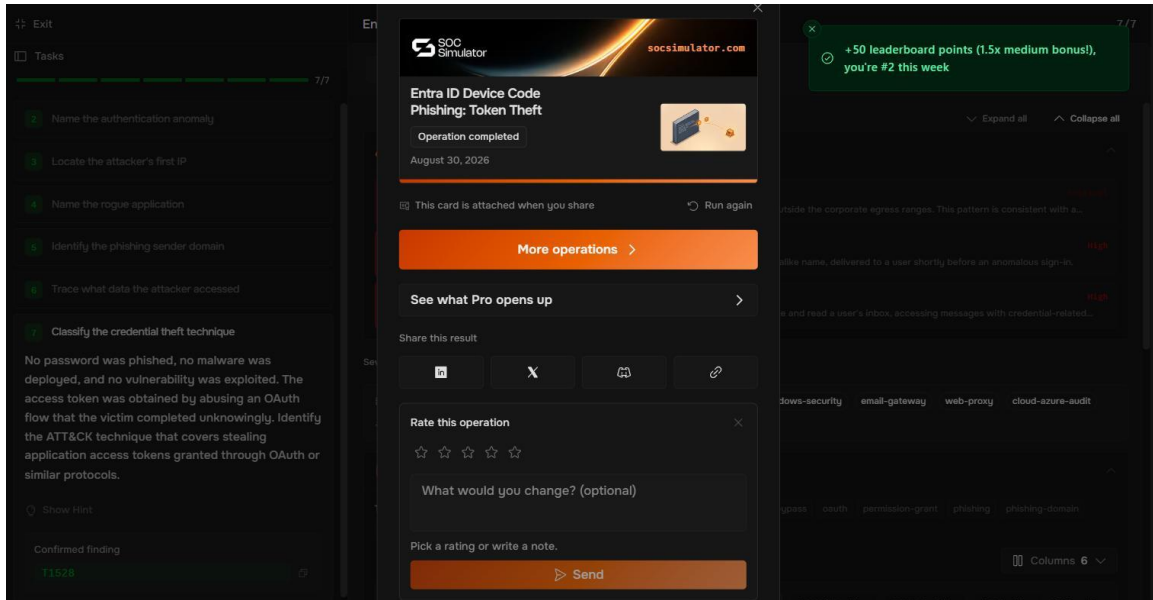


Figure 10. The platform's own threat write-up: summary and the section describing the Storm-2372 group and campaign.

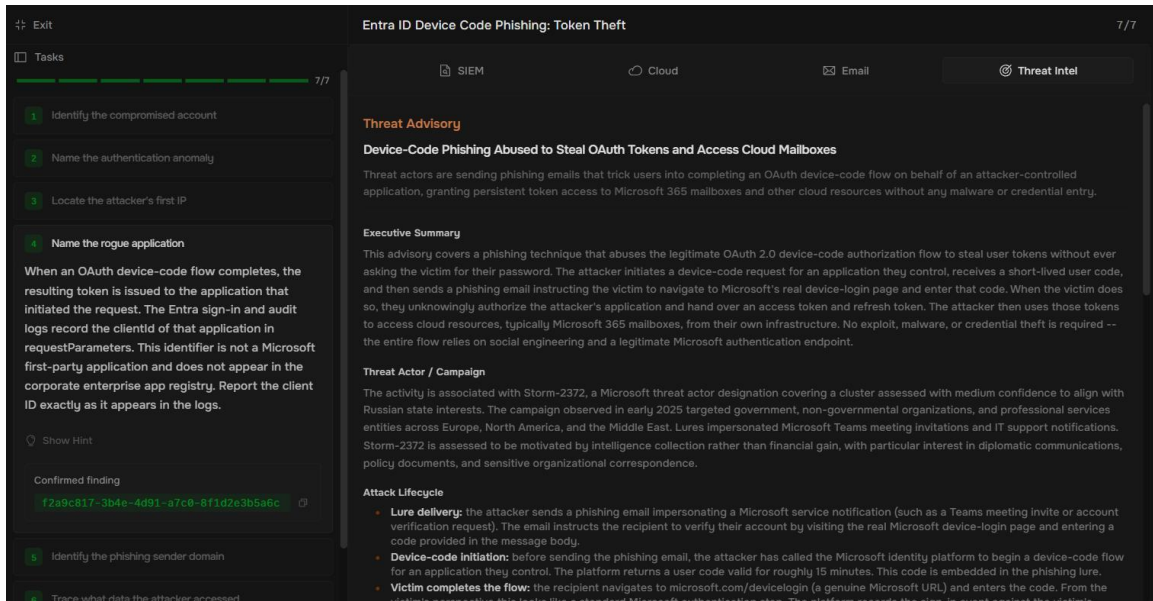


Figure 11. The platform's own threat write-up: how the attack unfolds, matching technique list, and suggested detections.

The screenshot displays the Microsoft Threat Intelligence platform interface. On the left, a 'Tasks' sidebar lists six steps: 1. Identify the compromised account, 2. Name the authentication anomaly, 3. Locate the attacker's first IP, 4. Name the rogue application (currently selected), 5. Identify the phishing sender domain, and 6. Trace what data the attacker accessed. Step 4 includes a detailed explanation of OAuth device-code flow and a 'Confirmed finding' with a client ID: `f2a9c817-3b4e-4d91-a7c0-8f1d2e3b5a6c`. The main content area, titled 'Entra ID Device Code Phishing: Token Theft', provides a comprehensive threat write-up. It describes the attack's goal (token theft for mailbox access) and lists three primary techniques: **Collection** (searching for high-value emails), **Persistence via refresh tokens** (tokens valid for weeks/months), and **MITRE ATTACK** (specifically Phishing: Spearphishing Link, Steal Application Access Token, Valid Accounts: Cloud Accounts, and Email Collection). Below these, 'Detection Opportunities' are listed, including alerts on Entra sign-in events, source IP correlation, Microsoft Graph API activity monitoring, new application registrations, refresh-token issuance events, and email header inspection. The section concludes with 'Mitigations and Hardening'.

Figure 12. VirusTotal lookup for ms-teams-notify.io — no record found.

The screenshot shows the VirusTotal search interface. At the top, a search bar contains the text 'URL, IP address, domain or file hash'. Below the search bar, a large circular icon with a folder and a trash can symbol is displayed. Underneath the icon, the text 'Item not found' is prominently shown. A message follows: 'Are you looking for advanced malware searching capabilities? Our threat intelligence offering can help, [learn more](#).' At the bottom, there is a button labeled 'Try a new search'.

Figure 13. VirusTotal details for 185.125.0.44 (0 of 91 flagged, small German hosting provider).

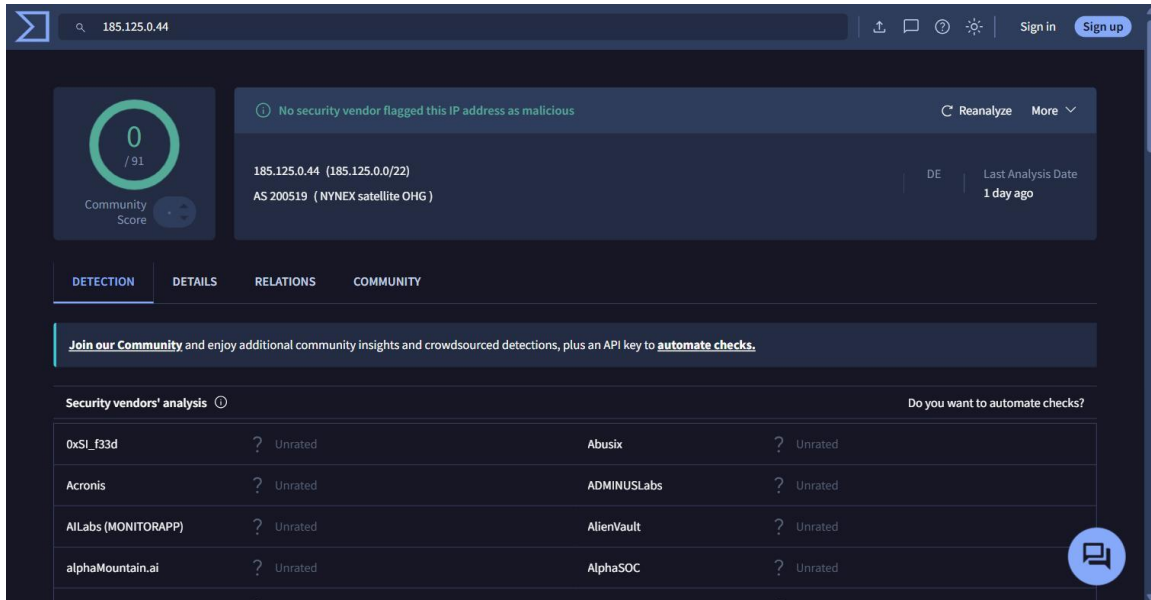


Figure 14. VirusTotal details for 185.125.0.91 (0 of 91 flagged, same hosting provider and address block).

